UNIVERSITY OF LONDON

BSc EXAMINATION 2022

For Internal Students of
Royal Holloway

DO NOT TURN OVER UNTIL TOLD TO BEGIN

IY3609: DIGITAL FORENSICS

IY3609R: DIGITAL FORENSICS – PAPER FOR FIRST SITS/RESIT CANDIDATES

Time Allowed: **TWO** hours

Attempt **three** questions.
No credit will be given for attempting any further questions.

Important Copyright Notice
This exam paper has been made available in electronic form
strictly for the educational benefit of current Royal Holloway students
on the course of study in question.
No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.
© Royal Holloway University of London 2022

Question 1 Nonvolatile Storage Forensics

(a) Hard drives are still used for near-line storage, frequently in the form of Storage Area Networks (SANs) or other forms of multi-drive configurations. This presents a number of challenges for forensic analysts.

Consider a NAS (Network Attached Storage) device with four drives that has been seized during a search where the NAS operating system will not provide access without credentials. The analyst decides to remove the drives from the enclosure and study the file systems directly.

How can the analyst identify how data of a logical volume is stored across multiple drives? Give a hypothesis and describe how this can be verified.

[13]

(b) Assume that the drive enclosure of question 1(a)(i) contained multiple drives, but that it was only possible to recover **one** of these. What is the likelihood that a **complete** file can be recovered from this single drive if we further assume that the enclosure had the four drives in a RAID-5 configuration? Identify which properties of the file sought after and the file system will contribute to the likelihood of a successful complete recovery.

[12]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 2 Legal and Regulatory Issues

(a) Several UK laws enable intelligence and law enforcement agencies to compel both individuals and service providers to give access to encrypted communication.

Consider a case where police have lawfully obtained encrypted communication (e.g. an encrypted email addressed to the suspect) between a party and the suspect.

The suspect does not disclose the contents of the email and is served a notice compelling disclosure of key material under RIPA section 49.

However, the suspect claims that he is no longer in possession of the private key required to reveal the key.

(i) How would the suspect (or a forensic expert engaged on his behalf by a solicitor) be able to prove that he was not in possession of the key material *at the time when the section 49 notice was given*? [8]

(ii) Assume that it has not been possible to prove that the suspect has or had control of the key required to obtain the plaintext. The prosecution still wishes to obtain the information in the email and obtains an Overseas Production Order under the Crime (Overseas Production Orders) Act 2019 from a Crown Court judge to compel retrieval from the sender located in the Pridnestrovian Moldavian Republic (Transnistria).

Give a reasoned consideration whether this warrant is likely to lead to the contents of the email being recovered. [8]

(b) Considering the issues surrounding the practicalities of a RIPA section 49 disclosure identified in question 2(a), it has been proposed to instead seek *targeted equipment interference warrants* under section 99(2) of the Investigatory Powers Act 2016.

This would e.g. allow the modification of encrypted messaging protocols to include a *silent* additional participant, after which messages would still be

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

end-to-end encrypted, but an additional end-to-end encryption be set up with a law enforcement entity, thereby disclosing plaintext.

Can this interference result in a legitimate challenge to the validity of the plaintext material obtained? Give a reasoned answer. [9]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 3 Memory Forensics

(a) A company has been the victim of a ransomware attack. The attack was rapidly traced to a machine of an employee working from home at the time owing to COVID restrictions.

The ransomware was copied onto a shared volume from the employee's machine based on event logs on the file server, but using *administrative credentials* rather than the employee's corporate credentials.

Internal investigators are now seeking to establish how the ransomware obtained the administrator credentials and whether there is an instance of negligence or malfeasance on the part of the employee. The employee claims to never have had any administrative credentials.

(i) The employee's machine had not been re-booted since the event was detected. The forensic investigators are hence seeking to obtain a memory image before imaging nonvolatile storage.

Which technique should be used for memory imaging if the machine in question is a current-generation laptop running Windows 10 with Secure Boot and other UEFI security features enabled? Give a reasoned answer. [9]

(ii) Assume that a memory image was successfully obtained in question 3(a)(i). Which memory data structures and process images should an investigator review particularly to prove or disprove the claim of the user not to have supplied administrator credentials? Give a brief, reasoned answer. [9]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

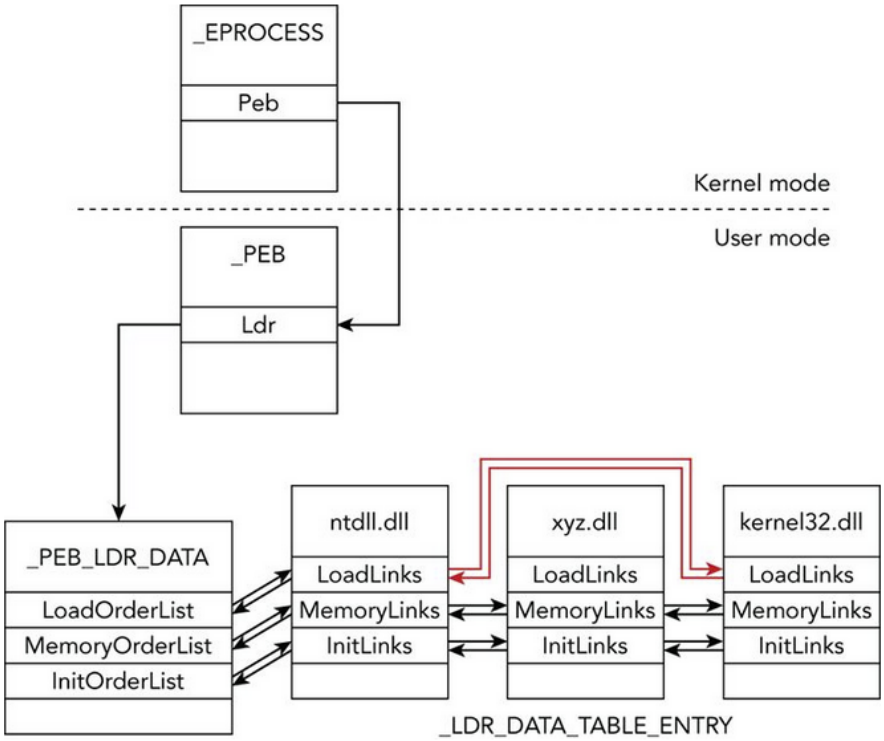
(b) A computer running Windows 10 is seized, but a removable SSD that was previously connected cannot be located. The investigator is able to obtain a memory image of the machine and is trying to establish whether the missing SSD may contain a specific version of a document.

How can the investigator, based on data found either in memory or non-volatile storage determine whether in-memory structures refer to the file system on the SSD, as well as the type of file system? Give a brief reasoned answer. [7]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 4 Malware Forensics

(a) During a memory dump analysis of process images on a Microsoft Windows system looking for malware, an investigator discovers that the data structure containing the list of all dynamically loaded libraries (DLL) for one process is irregular (see figure):



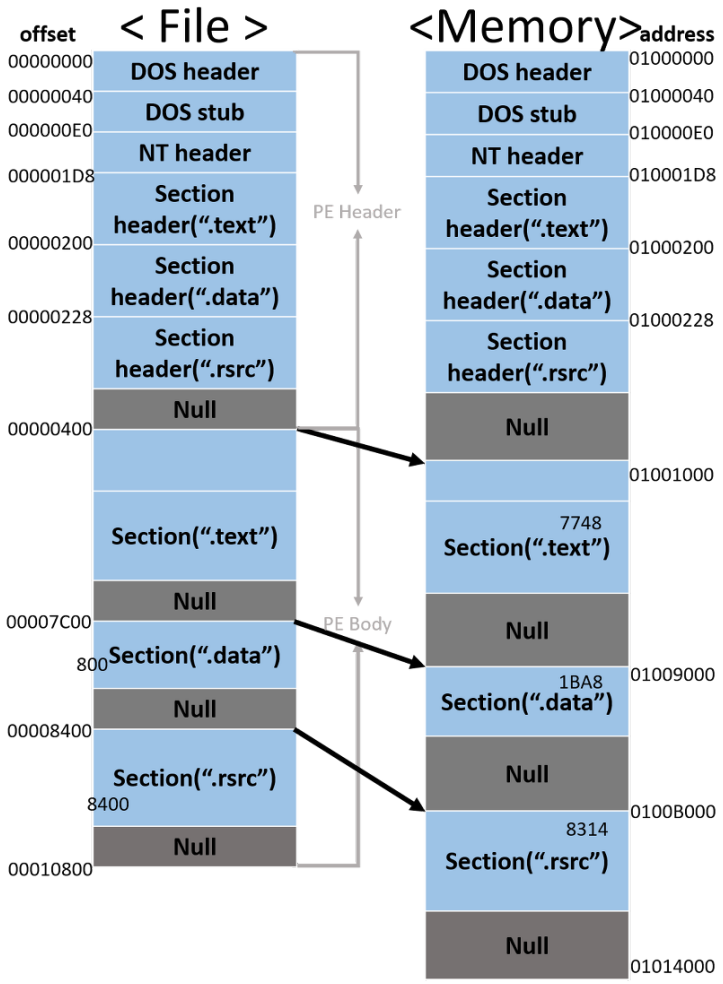
Process data structures identifying dynamically linked libraries

Explain why this discovery may indicate malicious activity, and identify the purpose and benefit for an adversary of such a manipulated structure. [9]

(b) In a further investigation, the forensic analyst studies the layout of a Microsoft Windows PE executable file on disk, and compares this to how the executable is laid out in memory.

The executable file on disk is identical (with a known hash value) to a known-good file, but the in-memory representation differs from the same executable loaded into memory of another system (see figure below)

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.



PE structures on disk and in memory

Explain why the in-memory structure may differ from one machine to another for the same executable file. Argue whether the hypothesis of the investigator that this is sufficient evidence for malware activity is correct. [9]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

(c) A memory image has been captured of a machine that is suspected of having been infected by a worm whose code and memory footprint are as yet unknown. The investigator is looking to corroborate if the worm has infected the system by analysing the memory used by the network protocol stack.

Identify which structures and artefacts would be indicative of the suspected activity and give a brief explanation. [7]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 5 Network Forensics

(a) A forensic analyst is seeking to identify the presence of advanced malware in her network. The malware appears to use sophisticated counter-forensics techniques that will self-destroy the malware if a detection attempt is noticed.

The analyst wishes to set up network surveillance (traffic capture) for suspicious traffic. How can this be configured so as to minimise the likelihood of detection? Give a detailed description and rationale. [9]

(b) The malware studied in question 5(a) will also seek to communicate with a command and control service, but is expected to rely on similarly sophisticated obfuscation techniques to conceal these channels.

Assume that the analyst has access to infrastructure services and their logs (e.g. firewalls, network address translators, network flow management devices, name servers).

Identify a possible hypothesis for identifying possible command and control channel traffic, and to link this back to an infected host. Identify which evidence from infrastructure services will be required to confirm or reject the hypothesis. [9]

(c) All communication of traders in a financial services institution are required to be retained by the regulator. Assume that the institution is hosting its own email server.

Which steps must the institution undertake to not only ensure retention of all email messages, but also that these cannot be tampered with and remain forensically sound? Give a brief, reasoned answer. [7]

END

SW

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.